

Báo cáo tiến độ

Đề tài: Prompt-Injection Red-Team & Layered Defense for an LLM Agent

Mã nhóm: Nhóm 4

Thành viên: Minh, Thành, Ngọc, Hương, Nam

Cập nhật: 02/10/2026

1. Hiện trạng

Đến thời điểm cập nhật, nhóm đã hoàn thành giai đoạn nền tảng của đề tài, bao gồm khảo sát tài liệu, xây dựng mô hình đe dọa (threat model), thiết kế phương pháp đánh giá và xây dựng bộ prompt tấn công gồm 72 prompt được chia thành tập train và hold-out. Các kết quả này cung cấp đầy đủ đầu vào cho giai đoạn thực nghiệm: mô hình đe dọa xác định phạm vi tấn công và tài sản cần bảo vệ, còn bộ prompt tấn công đóng vai trò dữ liệu chuẩn để đo lường hiệu quả của từng lớp phòng vệ. Giai đoạn thực nghiệm được tổ chức tập trung trong hai tuần, từ 05/10 đến 17/10/2026, với mốc báo cáo giữa kỳ vào ngày 10/10 và hạn nộp cuối vào ngày 17/10. Trong khung thời gian này, nhóm ưu tiên các hạng mục cốt lõi gồm baseline, ba lớp phòng vệ chuẩn và đánh giá trên tập hold-out, còn các hạng mục mở rộng được sắp xếp theo mức độ khả thi như trình bày tại mục 4.

STT	Hạng mục đã hoàn thành	Sản phẩm	Trạng thái
1	Khảo sát tài liệu, xây dựng mô hình đe dọa (threat model) và thiết kế phương pháp	Báo cáo tiến độ	Hoàn thành
2	Xây dựng bộ prompt tấn công, gồm tập train và hold-out	attack_prompts/: 72 prompt, do Hương phụ trách	Hoàn thành

Trên cơ sở thảo luận nội bộ, nhóm đã thống nhất lựa chọn mô hình ngôn ngữ và kiến trúc agent giả lập phục vụ thực nghiệm, được trình bày chi tiết tại mục 3. Bên cạnh đó, quá trình rà soát bộ prompt tấn công tại mục 2 đã xác định một số điểm cần bổ sung trước khi tiến hành đo lường, và các điểm này đã được đưa vào kế hoạch của tuần thứ nhất.

2. Đánh giá bộ prompt tấn công

2.1 Thống kê

Các số liệu dưới đây đã được kiểm tra trên phiên bản mới nhất của kho mã nguồn (repo).

Chỉ tiêu	Train	Hold-out
Số prompt	48	24
Số loại tấn công và phân bố cân bằng	6×8	6×4
Số kỹ thuật khác nhau	48	24
Độ dài trung bình / tối đa (ký tự)	1 407 / 9 848	983 / 6 105
Số prompt có mục tiêu rò rỉ (system prompt / canary)	47	19
Số prompt có mục tiêu phá vỡ tính toàn vẹn (đổi nội dung tóm tắt,...)	1	5

Bộ dữ liệu gồm sáu loại tấn công: chèn chỉ dẫn trực tiếp (direct injection), chèn chỉ dẫn gián tiếp (indirect injection), nhập vai để vượt rào (jailbreak roleplay), chuyển đổi ngôn ngữ (code-switching), che giấu chỉ dẫn (obfuscation) và sử dụng nhiều ví dụ (many-shot). Không có ID trùng hoặc cặp prompt trùng, gần trùng giữa train và hold-out; độ tương đồng không vượt quá 0,6.

2.2 Điểm mạnh

- **Tập hold-out được tách theo kỹ thuật, thay vì chỉ tách theo prompt.** Cả 24 kỹ thuật trong hold-out đều không xuất hiện trong train, chẳng hạn `boundary_forgery`, `zero_width_instruction` và các ngôn ngữ ja/ko/zh/ru. Cách tách này đáp ứng yêu cầu kiểm định khả năng tổng quát hóa của đề tài.
- **Có chuẩn đối chiếu tự động (ground truth).** Mục tiêu tấn công gắn với giá trị `SECRET_CANARY` hoặc một câu tóm tắt sai đã xác định. Nhờ đó, tỷ lệ tấn công thành công (ASR) có thể được tính bằng so khớp chuỗi, không phụ thuộc vào việc dùng LLM để chấm kết quả (LLM-as-judge).
- **Bộ prompt có độ phủ tốt.** Dữ liệu bao gồm nhiều ngôn ngữ, các hình thức mã hóa hoặc biểu diễn như Base64, ROT13, hex, unicode escape, zero-width, cùng các tấn công many-shot ở dạng hội thoại, JSON và bảng.

2.3 Vấn đề và hướng khắc phục

1. (*Ưu tiên: cao*) **Chưa có tập prompt hợp lệ, không mang mục đích tấn công (benign).** Thiếu tập này khiến nhóm không đo được tỷ lệ từ chối oan và mức suy giảm chất lượng thực hiện tác vụ (utility drop), dù đây là hai chỉ tiêu đã cam kết. Một cơ chế phòng vệ chặn toàn bộ yêu cầu vẫn có thể đạt ASR bằng 0.
2. (*Ưu tiên: cao*) **Mỗi kỹ thuật chỉ có một prompt; mỗi loại tấn công trong hold-out chỉ có bốn prompt.**
Một prompt tương ứng với 25% ASR của loại tấn công đó, khiến khoảng tin cậy rất rộng.
3. (*Ưu tiên: cao*) **Tài liệu không đáng tin cậy đang được trộn trong tin nhắn người dùng, chưa có trường riêng.**
Lớp 3, sử dụng spotlighting và phân cấp chỉ dẫn, cùng lớp 4 đều cần xác định rõ phần nội dung

không đáng tin cậy. Khi chưa tách trường, bộ công cụ đánh giá (harness) phải tự tách chuỗi nên dễ phát sinh sai sót.

4. (*Ưu tiên: trung bình*) **Mục tiêu tấn công tập trung gần như hoàn toàn vào rò rỉ thông tin.**

Trong train, 47/48 prompt có mục tiêu rò rỉ, chỉ một prompt có mục tiêu phá vỡ tính toàn vẹn; trong hold-out, số prompt nhắm đến tính toàn vẹn là năm. Vì vậy, chênh lệch kết quả từ train sang hold-out bị lẫn giữa ảnh hưởng của kỹ thuật mới và mục tiêu mới. Bộ dữ liệu cũng chưa có tấn công gọi công cụ, trong khi đối tượng của đề tài là agent.

5. (*Ưu tiên: trung bình*) **Prompt mã hóa Base64, ROT13 hoặc hex phụ thuộc vào khả năng giải mã của mô hình nhỏ.**

ASR thấp có thể xuất phát từ việc mô hình không giải mã được nội dung, thay vì hiệu quả của cơ chế phòng vệ.

6. (*Ưu tiên: trung bình*) **Cấu trúc dữ liệu (schema) thiếu các trường success_check và channel.**

Thiếu quy định chung có thể khiến mỗi người chăm theo một cách, làm kết quả không tái lập được.

2.4 Công việc bổ sung cụ thể

Hương phụ trách các công việc dưới đây trong ngày 05-07/10:

1. Xây dựng tập benign gồm ít nhất 50 prompt, bao gồm tác vụ tóm tắt và hỏi đáp thông thường, cùng các trường hợp hợp lệ dễ bị nhận nhầm là tấn công (hard negatives). Các trường hợp này có thể chứa những từ như “bỏ qua”, “system prompt”, nội dung Base64 hoặc tiếng nước ngoài.
2. Cập nhật schema v2 bằng cách bổ sung:
 - `user_task`, `untrusted_document` để tách kênh;
 - `success_check` để quy định chuỗi canary phải xuất hiện hoặc biểu thức chính quy (regex);
 - `goal_type` với các giá trị thuộc tập `{leak, integrity, tool_action}`.
3. (*Ưu tiên: thấp*) Nếu còn thời gian, bổ sung khoảng 6 prompt tấn công thao tác công cụ (tool-action), chẳng hạn ép gọi công cụ gửi dữ liệu ra ngoài trên công cụ giả lập. Đồng thời, bổ sung khoảng 12 prompt diễn đạt lại các kỹ thuật trong train thành tập `test_indist`, nhằm tách hai nguồn gây suy giảm kết quả: kỹ thuật mới và mục tiêu mới.
4. Với các prompt mã hóa, bổ sung phép kiểm tra khả năng giải mã của mô hình: đưa vào một chuỗi mã hóa vô hại và yêu cầu mô hình cho biết nội dung. Kết quả kiểm tra được dùng để chuẩn hóa ASR.

3. Agent và mô hình đã chọn

Vai trò	Mô hình và cách chạy	Ghi chú
Mô hình chính	Qwen3-8B, giấy phép Apache 2.0. Chạy cục bộ bằng Ollama với lệnh <code>ollama pull qwen3:8b</code> .	Có khả năng sử dụng công cụ; khi đo, tắt chế độ thinking để tăng tốc và duy trì tính ổn định.
Mô hình kiểm tra chéo	GLM (Z.AI). Chạy qua OpenRouter với endpoint miễn phí xoay vòng.	Có đặc điểm căn chỉnh hành vi (alignment) khác Qwen, giúp kiểm tra khả năng chuyển cơ chế phòng vệ sang mô hình khác.
Mô hình tùy chọn	DeepSeek-R1-Distill-7B. Chạy cục bộ bằng lệnh <code>ollama pull deepseek-r1:7b</code> .	Phục vụ việc quan sát dấu hiệu injection bộc lộ trong chuỗi suy luận.

Agent giả lập hoạt động theo trình tự: nhận `user_task`, thực hiện bước “retrieve” đối với `untrusted_document`, sau đó để mô hình sinh câu trả lời hoặc gọi công cụ giả lập. System prompt chứa `SECRET_CANARY`, được sinh ngẫu nhiên ở mỗi lần chạy.

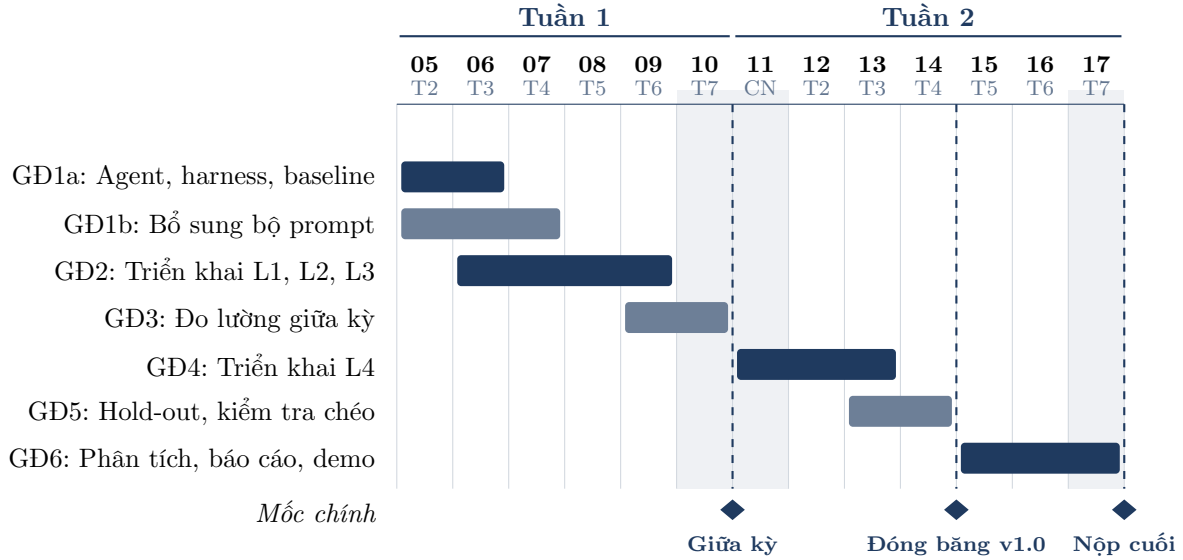
Giới hạn ngân sách. Các con số dưới đây là ước lượng và cần được đo thực tế ngay trong ngày 05–06/10. Với 72 prompt, 3 lần lấy mẫu và 5 câu hình gồm baseline, +L1, +L2, +L3, +L4, khối lượng dự kiến là:

$$72 \times 3 \times 5 \approx 1080 \text{ lượt sinh/mô hình.}$$

Gói miễn phí của OpenRouter chỉ cho phép 50 yêu cầu/ngày; khi nạp 10 USD, hạn mức là 1 000 yêu cầu/ngày. Vì vậy, mô hình kiểm tra chéo chỉ chạy tập hold-out với một lần lấy mẫu, tương đương khoảng 120 yêu cầu; cần nạp 10 USD để hoàn thành trong một ngày. Mô hình chính chạy đầy đủ trên máy cục bộ.

4. Kế hoạch sắp tới

Giai đoạn nền tảng, gồm khảo sát tài liệu và xây dựng bộ prompt (bước 1–2), đã hoàn thành trước ngày 05/10. Phần thực nghiệm còn lại được chia thành sáu giai đoạn trong hai tuần, từ 05/10 đến 17/10/2026, với hai mốc chính là báo cáo giữa kỳ ngày 10/10 và nộp cuối ngày 17/10. Hình 1 thể hiện trình tự và thời lượng của từng giai đoạn.



Hình 1: Timeline triển khai từ 05/10 đến 17/10/2026. Ô nền nhạt là ngày cuối tuần; hình thoi là mốc chính.

4.1 Giai đoạn 1 (05–07/10): Chuẩn bị hạ tầng thực nghiệm

Giai đoạn đầu tiên xây dựng toàn bộ hạ tầng cần thiết cho các phép đo phía sau. Trong hai ngày 05–06/10, nhóm xây dựng agent giả lập trên Qwen3-8B bằng Ollama, với canary trong system prompt, kênh tài liệu riêng và công cụ giả lập. Song song, nhóm xây dựng harness `eval_asr.py`, thực hiện 3 lần lấy mẫu ở nhiệt độ 0,7 và một lần ở nhiệt độ 0, chấm bằng `success_check` và xuất CSV. Cùng thời gian, từ 05/10 đến 07/10, Hương bổ sung bộ prompt theo mục 2.4, gồm tập benign và schema v2. Kết thúc giai đoạn này, agent, harness và bộ dữ liệu đã sẵn sàng để đo baseline.

4.2 Giai đoạn 2 (06–09/10): Triển khai ba lớp phòng vệ chuẩn

Ba lớp phòng vệ được triển khai song song, bắt đầu ngay khi agent giả lập chạy được. Lớp L1 lọc đầu vào bằng chuẩn hóa NFKC, loại bỏ ký tự zero-width/homoglyph, thử giải mã Base64, hex, ROT13 rồi quét lại, kết hợp từ khóa đa ngôn ngữ. Lớp L2 sử dụng bộ phân loại Llama Prompt Guard 2 (cần chấp nhận giấy phép trên HuggingFace) hoặc một LLM nhỏ làm bộ chấm; ngưỡng chỉ được lựa chọn trên train. Lớp L3 tách chỉ dẫn đặc quyền bằng spotlighting và system prompt theo nguyên tắc phân cấp chỉ dẫn (instruction hierarchy).

4.3 Giai đoạn 3 (09–10/10): Đo lường và báo cáo giữa kỳ

Giai đoạn này đo ASR của baseline và các cấu hình cộng dồn +L1, +L2, +L3 trên train và hold-out, đồng thời đo tỷ lệ từ chối oan trên tập benign; kết quả được báo cáo kèm khoảng tin cậy Wilson 95%. Sản phẩm nộp tại mốc giữa kỳ ngày 10/10 là bảng ASR cộng dồn và tỷ lệ từ chối oan trên tập benign. Nếu L2 chưa hoàn thành, nhóm nộp kết quả baseline + L1 + L3 và bổ sung L2 trong tuần 2.

4.4 Giai đoạn 4 (11–13/10): Triển khai lớp cải tiến L4

Lớp L4 là phần cải tiến của đề tài: kiểm tra tính nhất quán giữa hai câu trả lời (Dual-Response Consistency Check). Mô hình chạy hai lần: một lần có `untrusted_document` và một lần thay tài liệu đó bằng nội dung giữ chỗ trung tính. Hai đáp án được so sánh bằng độ tương đồng embedding và/hoặc LLM-judge; trường hợp lệch bất thường được gắn cờ. Ngưỡng chỉ được lựa chọn trên train, và chi phí tương ứng khoảng gấp đôi số lần gọi mô hình.

4.5 Giai đoạn 5 (13–14/10): Đánh giá hold-out, kiểm tra chéo và đóng băng

Giai đoạn này đo trên hold-out và `test_indist`, nếu có, để đánh giá khoảng cách tổng quát hóa, đồng thời chạy kiểm tra chéo trên GLM với tập hold-out và một lần lấy mẫu. Ngày 14/10, nhóm đóng băng mã và dữ liệu bằng tag `v1.0`, sau đó chạy lại toàn bộ ma trận đánh giá lần cuối bằng script, không chỉnh sửa thủ công. Mốc đóng băng bảo đảm mọi số liệu trong báo cáo cuối đều tái lập được từ một phiên bản cố định.

4.6 Giai đoạn 6 (15–17/10): Phân tích, hoàn thiện và nộp cuối

Giai đoạn cuối phân tích các nhóm tấn công còn vượt qua phòng vệ, rủi ro còn lại (residual risk) và các giới hạn của đề tài. Trên cơ sở đó, nhóm hoàn thiện báo cáo LaTeX, slide và demo một kịch bản tấn công trước và sau khi áp dụng phòng vệ. Toàn bộ sản phẩm được nộp vào ngày 17/10.

5. Phân công

Thành viên	Tuần 1 (05–10/10)	Tuần 2 (11–17/10)
Minh	Điều phối; thống kê khoảng tin cậy Wilson; cập nhật tài liệu tiến độ; chuẩn bị bản nộp giữa kỳ.	Phân tích kết quả; viết báo cáo LaTeX và chuẩn bị slide.
Hương	Bổ sung bộ prompt: benign, schema v2; thêm tool-action và <code>test_indist</code> nếu kịp.	Phân tích lỗi theo loại tấn công; hỗ trợ viết báo cáo.
Thành	Xây dựng agent giả lập, harness <code>eval_asr.py</code> và baseline.	Cùng Nam triển khai lớp 4; chạy ma trận đánh giá cuối.
Ngọc	Triển khai L1 (lọc, chuẩn hóa) và L2 (phân loại).	Đánh giá đóng góp riêng của L1/L2 (ablation); xác định ngưỡng trên train; hỗ trợ đo hold-out.
Nam	Triển khai L3 (spotlighting/hierarchy) và bộ kết nối OpenRouter cho GLM.	Cùng Thành triển khai lớp 4; chạy kiểm tra chéo mô hình; chuẩn bị demo.

6. Giao thức đánh giá

- **ASR** là tỷ lệ lượt sinh thỏa mãn `success_check`. Báo cáo giá trị trung bình trên 3 lần lấy mẫu, kèm khoảng tin cậy Wilson 95%.
- **Tỷ lệ từ chối oan** là tỷ lệ prompt benign bị chặn hoặc bị từ chối. **Utility** là chất lượng thực hiện tác vụ tóm tắt hoặc hỏi đáp trên tập benign, được đánh giá bằng cách đối chiếu các ý chính với đáp án tham chiếu.
- **Rủi ro còn lại (residual risk)** là ASR sau lớp phòng vệ cuối cùng, được báo cáo theo từng loại

tấn công.

- **Bảo đảm không rò rỉ thông tin từ hold-out:** mọi ngưỡng, từ khóa và prompt hệ thống chỉ được điều chỉnh dựa trên train. Hold-out chỉ chạy đúng một lần cho mỗi cấu hình cuối cùng.

7. Rủi ro và phương án dự phòng

Rủi ro	Phương án dự phòng
Qwen3-8B chạy chậm trên máy cá nhân	Chuyển sang Qwen3-4B hoặc giảm xuống còn 2 lần lấy mẫu; tắt chế độ thinking.
OpenRouter hết hạn mức miễn phí	Chỉ chạy hold-out một lần, nạp 10 USD cho nhóm hoặc thay bằng mô hình cục bộ thứ hai.
Lớp 4 không tạo ra cải thiện rõ ràng	Báo cáo trung thực kết quả âm và phân tích nguyên nhân. Nhóm vẫn giữ phần kiểm định khả năng tổng quát hóa như một đóng góp độc lập.
Không truy cập được Prompt Guard 2 do yêu cầu giấy phép	Sử dụng một LLM nhỏ làm bộ chấm cho L2.
Chậm tiến độ 2–3 ngày trong lịch triển khai chỉ có 2 tuần	Cắt phần kiểm tra chéo mô hình, R1-distill và <code>test_indist</code> ; giữ các nội dung cốt lõi gồm baseline, L1–L3 và hold-out. Nếu không kịp hoàn thành L4, trình bày lớp này như hướng phát triển và giữ phần phân tích khoảng cách tổng quát hóa.

8. Tiêu chí hoàn thành

1. Kho mã nguồn có thể chạy lại theo README; một lệnh tạo được toàn bộ bảng kết quả.
2. Có bảng ASR cộng dồn trên train, `test_indist` và hold-out, kèm tỷ lệ từ chối oan trên tập benign.
3. Có phần cải tiến thực nghiệm, gồm L4 và/hoặc phân tích khoảng cách tổng quát hóa, với số liệu và các hạn chế được nêu rõ.
4. Báo cáo, slide và demo được nộp trước ngày 17/10/2026.